

PROJECT CHARTER &
TECHNICAL DESIGN DOCUMENT

Redshift SOC

Segmented SOC Reference Environment with Centralized Detection & AI-Assisted Alert Triage

Field	Value
Document Type	Project Charter / Technical Design Document (TDD)
Project Codename	Redshift SOC
Planned Sub-Component	Triarc AI-assisted alert triage (True/False Positive correlation)
Document Status	Approved for Implementation
Document Owner	Project Lead / Sole Engineer
Classification	Internal Portfolio / Training Environment

1. Executive Summary

Redshift SOC is a self-contained segmented network security environment set up to enable, test, and validate the core functionalities of a Security Operations Center (SOC). The SOC environment has four major pillars of focus : perimeter security; collection of endpoint telemetry; collection and correlation of logs centrally; and eventually, the security alert triage based on Artificial intelligence assistance. The following document elaborates on the problem statement, system requirements, and architectural decision choices made, along with any security and phase based plan in place prior to beginning the implementation of the system.

Any key design decision made must have clear reasoning and must be understood independently of the implementation process.

The SOC environment can be fully built in a single ordinary laptop with 16 GB of RAM, which mirrors the most realistic security scenario where security administrators might seek to demonstrate the functionality of their intended SOC architecture along with the security detection capabilities without consuming extensive financial or organizational resources for infrastructure or cloud services.

2. Problem Statement & Business Case

Security teams have to do exactly what this audience requires to do- prove to auditors, bosses, and now me, hiring managers, that the diagram they drew of a segregated network and the log list they produced isn't just words but actually a working implementation of this security goal. For example, showing a diagram doesn't prove an attacker is isolated and can't get to a prized asset and showing logs does not demonstrate my SIEM actually gets and correlates those logs.

Redshift SOC provides this by taking such an example diagram into a working implement, attacking it and showing that it successfully generated and collected and in a simulated SIEM environment, using AI and automated techniques to reduce the signals to noise, the resulting alerts.

2.1 Objectives

- * Segment the network: Separate untrusted attacker traffic to the protected victim / production network. A stateful firewall will enforce traffic between the two networks with explicit rules and with a "default deny" which will block all traffic unless expressly allowed by the explicit rule.
- * Collect security telemetry: Gather crucial endpoint and network security events, such as process execution, authentication events, web traffic, and firewall determinations, and push all this data to a centralized logging platform which can be searched/audited centrally.
- * Validate detection coverage: Conduct Red team activities to simulate attacks based on techniques identified in the MITRE ATT&CK framework. The purpose of this exercise is to ensure that the expected security telemetry exists, is successfully collected, and can be searched in the central logging platform.

* Reduce alert fatigue on analysts: Add an AI layer with a triage engine called Triarc which can assist analysts in investigating security events. Triarc would analyze incoming alerts against known-benign and known-malicious patterns and could give a recommendation whether the alert is a True Positive (TP) or a False Positive (FP) and offer supporting reasoning for the determination.

3. Requirements

3.1 Functional Requirements

ID	Requirement	Priority
FR-1	The firewall shall implement a default-deny configuration between the attacker segment and the protected segment, allowing only traffic explicitly permitted by firewall rules.	Must
FR-2	The firewall shall log both allowed and blocked traffic to support security analysis and correlation during investigations.	Must
FR-3	The Windows endpoint must record detailed process execution telemetry instead of relying only on default Windows OS logs.	Must
FR-4	The Linux endpoint will host a monitored web application and provide an authentication surface for controlled attack simulations.	Must
FR-5	Endpoint and firewall logs will be centrally collected and searchable through a unified logging platform.	Must
FR-6	The logging platform shall support saved searches, dashboards, and scheduled alerts based on collected security logs.	Should
FR-7	The Triarc AI-assisted component should be able to receive a generated security alert and classify it as either a True Positive or False Positive , with a clear and justifiable reason.	Should — Phase 2
FR-8	All test simulations used to validate detection coverage shall be documented and mapped to their associated MITRE ATT&CK techniques .	Should

3.2 Non-Functional Requirements

ID	Requirement
NFR-1	The entire environment must run concurrently on a single host with 16GB RAM, without requiring all components to be powered on simultaneously at all times.
NFR-2	Component configuration must be reproducible from documentation alone, without relying on undocumented manual steps.
NFR-3	Static IP addressing must be used throughout, to keep configuration, logs, and documentation consistent across rebuilds.
NFR-4	All infrastructure changes and significant incidents encountered during build must be documented with root cause, not just the resolution.

3.3 Constraints

Hardware ceiling: 16GB RAM per individual laptop. Usable budget within VM(s) ~11-12 GB (due to host OS/hypervisor).

Single engineer, single instance – No dedicated Staging environment, changes verified against the "real" build.

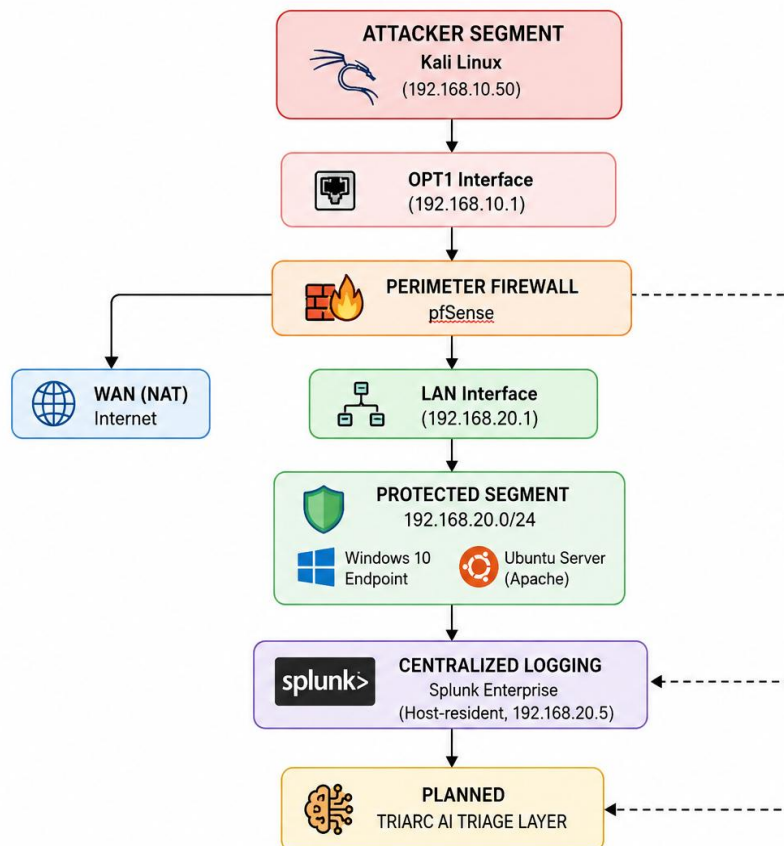
Freeware/Community editions of everything (pfSense CE, Splunk Free license tier etc)-No budget for paid licenses.

4. Proposed Architecture

4.1 Design Principles

Default-deny at the network perimeter with only explicitly allowed rules to the smallest required source, destination, port. Segmentation based on trust level not device type; the compromised host is on its own network with no route to the protected network except across the firewall. Centralized logging and monitoring as a first-class requirement; the log aggregator is reachable from every zone from inception. All security controls and their corresponding policies are always tested positively (expected/allowed traffic arrives) and negatively (unintended/blocked traffic does not arrive).

4.2 Logical Architecture



4.3 Component Decisions & Rationale

Decision	Chosen Approach		Rationale
Hypervisor	VMware Workstation Pro		Multiple isolated virtual switches required for segmentation; does not require repartitioning the host.
Firewall platform	pfSense Community Edition		No licensing cost; industry-relevant FreeBSD-based stateful firewall with a full rule engine and logging.
Firewall interface count	Three (WAN / LAN / OPT1) decided at design time		A single WAN interface cannot simultaneously provide real internet egress for protected hosts and serve as the attacker segment's entry point without conflict; this was identified as an architectural requirement before build, not discovered mid-build.
Windows endpoint OS	Windows 10 over Windows 11		Reduces RAM footprint (3GB vs. 4GB minimum) and removes TPM 2.0 / Secure Boot dependencies that add no detection-engineering value in this context.
Linux endpoint role	Ubuntu Server, headless, hosting Apache		Matches common small-environment production patterns (single host, multiple services) and provides both a web attack surface and an SSH authentication surface.
Logging platform placement	Splunk Enterprise installed on the host laptop rather than a dedicated VM		Removes an entire VM's RAM overhead from the budget; a documented, deliberate trade-off given the hardware constraint (NFR-1).
Log transport	Splunk Universal Forwarder (endpoints) and syslog (firewall)		Matches how these platforms are integrated with Splunk in production environments; keeps the build resume-relevant.
Attack simulations causing unintended impact outside the isolated segment	Low	High	All simulations confined to the lab's private, non-routed subnets; no live malware or unpatched-CVE exploitation used.
Log source misconfiguration producing silent data loss (forwarder reports a healthy connection but is not actually collecting anything)	Medium	Medium	Verification of both the transport (connection to indexer) and the input configuration (files/channels actually being monitored) as two independent checks.

6. Implementation Roadmap

The build is executed in discrete, independently-verifiable phases. Each phase has a defined objective, a set of verification criteria, and is not considered complete until those criteria are demonstrated — not merely attempted.

Phase	Deliverable	Exit Criteria
1	Architecture & environment plan	Network segmentation plan, IP scheme, and resource budget documented and approved before any installation begins.

2	Hypervisor & base networking	Isolated virtual networks created and verified in the virtualization platform.
3	Perimeter firewall	Three-interface firewall deployed; default-deny confirmed; explicit rules created and verified with positive and negative tests.
4	Windows endpoint	Endpoint deployed, statically addressed, reachable from the protected segment.
5	Linux endpoint	Endpoint deployed, statically addressed, SSH access verified cross-platform.
6	Attacker platform	Deployed on the isolated segment; segmentation isolation verified before any firewall rule exists.
7	Web application target	Web server deployed with custom content and confirmed live access logging.
8	Firewall rule validation	All intended attacker-to-endpoint paths validated positive and negative; logging confirmed.
9	Centralized logging platform	Logging platform deployed and reachable from the protected segment; dedicated index created.
10	Log source onboarding	All planned log sources (endpoint telemetry, web/auth logs, firewall syslog) confirmed actively arriving in the logging platform.
11	Attack simulation & detection validation	Each planned MITRE ATT&CK-mapped simulation executed and corresponding telemetry confirmed present and searchable.
12 (Planned)	Triarc — AI-assisted alert triage	AI component able to ingest an alert and return a True/False Positive recommendation with supporting rationale, validated against a labeled test set of true and false positives generated in Phase 11.

7. Planned Extension: Triarc (AI-Assisted Alert Triage)

Triarc is the planned name for the project's AI-assisted correlation layer, scoped as a forward-looking extension once the core detection rules (Phase 11+) are established and generating a meaningful volume of both true-positive and false-positive alerts to learn from.

7.1 Problem It Addresses

A significant portion of real SOC analyst time is spent triaging alerts that turn out to be benign — expected administrative activity, known-good automation, or noisy detection logic that has not yet been tuned. Triarc's purpose is to reduce this burden by providing a first-pass recommendation an analyst can quickly confirm or override, rather than starting every investigation from zero.

7.2 Conceptual Approach

- Ingest a fired alert (the underlying Splunk search result and relevant surrounding context — process lineage, source/destination, recent history for that host).
- Correlate against a labeled reference set built from this lab's own attack simulations (known true positives) and normal baseline activity (known false positives).
- Return a recommended classification (True Positive / False Positive / Needs Review) with a plain-language rationale citing the specific signals that drove the recommendation.

- Log every recommendation and the analyst's eventual decision, to make the correlation logic's accuracy measurable over time rather than a black box.

7.3 Success Criteria

- Triarc's recommendation matches the analyst's final determination on a clear majority of a held-out validation set of alerts.
- Rationale provided is specific and auditable (references actual fields/values from the alert), not a generic template response.
- False negative rate (Triarc recommending False Positive on an alert that was actually a true positive) is tracked and minimized as the highest-priority error type, since under-triaging a real incident is more costly than over-triaging a benign one.

8. Overall Project Success Criteria

- A verifiably enforced network segmentation boundary, demonstrated with both passing and failing connectivity tests.
- A centralized logging platform receiving live data from every planned source, independently verified for each source.
- A documented set of attack simulations, each mapped to a MITRE ATT&CK technique, with confirmed corresponding telemetry.
- A public, well-documented repository suitable for technical portfolio review, including root-cause write-ups of real issues encountered — treated as evidence of engineering capability, not omitted in favor of a idealized narrative.
- (Phase 2) A working AI-assisted triage component meeting the criteria defined in Section 7.3.